



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

COMENTÁRIOS DO GESTOR

SETD - Secretaria de Estado de Transformação Digital

1. Introdução

Este documento orienta a manifestação da **SETD** na fase de comentários do gestor. Conforme o caso, a manifestação poderá tratar dos achados e situações de inadequação registrados no Relatório Individual Preliminar, dos itens avaliados como não conformes na etapa de avaliação das evidências ou da ausência de resposta válida ao questionário iGovTI 2026.

A manifestação deve ser apresentada no questionário eletrônico de comentários do gestor, observando-se apenas as seções disponibilizadas para a organização.

Quando houver achados, a organização deverá informar se concorda ou discorda de cada situação apontada e, quando couber, apresentar comentários, justificativas e documentação comprobatória. Nas questões-base indicadas na seção de reavaliação de evidências, a organização poderá apresentar esclarecimentos, retificações ou evidência suplementar para reanálise dos itens avaliados como não conformes. Quando não houver resposta válida ao questionário iGovTI 2026, a manifestação deverá se limitar a esclarecimentos, comprovação de eventual envio anterior ou justificativa para a ausência de resposta.

A etapa de comentários do gestor é desejável, mas tem caráter opcional para a organização auditada. Sua finalidade é permitir que o gestor apresente esclarecimentos sobre fatos, retifique informações, informe providências adotadas ou planejadas e encaminhe documentação complementar pertinente.

Considerando a natureza da solicitação, relativa aos comentários dos gestores sobre achados de auditoria, o prazo para finalização e envio do questionário é **improrrogável**, conforme o item 8.4 do Manual de Auditoria do TCE-RJ, e se encerra em **10/07/2026**.

Recomenda-se que o questionário seja preenchido com antecedência. Eventuais solicitações de esclarecimento poderão ser encaminhadas para o e-mail **auditoriati@tcerj.tc.br**.



Achado 1 – Estrutura de TIC insuficiente para coordenar, gerir e sustentar a tecnologia da informação.

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **SETD** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Posicionamento organizacional inadequado da área de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **SETD** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “Ausência de força de trabalho dedicada à TIC ou à segurança da informação.” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“A organização não definiu o quantitativo necessário de pessoal de TIC e segurança da informação.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Ausência de cargos, funções, perfis ou ocupações específicas de TIC e segurança da informação.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Perfis profissionais de TIC e segurança da informação inexistentes, insuficientes ou não utilizados na escolha de gestores.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Lacunas de competências dos colaboradores e gestores de TIC e segurança da informação não são identificadas ou tratadas.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **SETD** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “**Inexistência ou insuficiência do catálogo de serviços de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência ou fragilidade na definição e no monitoramento de níveis mínimos de serviço de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Inexistência ou fragilidade do processo de gestão de incidentes de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **SETD** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Inexistência ou fragilidade de processo formal e padronizado para contratações de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Contratações de TIC sem análise prévia e aprovação técnica obrigatória da área de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



Reavaliação de evidências

Esta seção permite que a organização apresente comentários, esclarecimentos, retificações ou evidência suplementar para reavaliação de questões que tiveram pelo menos um item ou subitem classificado como não conforme na etapa de avaliação das evidências.

Consulte no Relatório Individual Preliminar e nos anexos correspondentes os itens específicos avaliados como não conformes. A apresentação de nova evidência é opcional e deve se limitar a arquivo em formato PDF ou ZIP.



Questão 2102. A organização possui plano de tecnologia da informação vigente.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2102 - b) o plano de TI é publicado na internet, para fácil acesso de partes interessadas e da sociedade
Resposta informada pelo auditado	Sim
Avaliação	O documento não apresenta evidência de publicação em sítio eletrônico público acessível à sociedade. Embora contenha links de autenticação do sistema SEI para consulta de documentos internos, não restou demonstrada a disponibilização do plano em página da internet, conforme exigido pelo critério de transparência.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2201. A organização elabora um catálogo de serviços de tecnologia da informação e monitora níveis de serviço.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2201 - A organização elabora um catálogo de serviços de tecnologia da informação e monitora níveis de serviço.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A avaliação realizada indica que o documento apresentado é um Acordo de Cooperação Técnica, o qual não se configura como catálogo de serviços de TI nem estabelece instrumentos para a gestão e o monitoramento de níveis de serviço (ANS). A evidência limita-se a descrever ações de cooperação entre os órgãos, sem conter requisitos de gestão de serviços de TI exigidos pelo critério. Constata-se a ausência de catálogo de serviços de TI estruturado e de mecanismos de acompanhamento de indicadores de desempenho.
Item avaliado	Q2201 - a) o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes)
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que não há catálogo de serviços de TI com as metas operacionais exigidas, como prazos, horários de suporte ou pontos de contato. O documento limita-se a um cronograma de execução de ações de cooperação, sem definição de níveis de serviço voltados aos usuários. Falta a formalização de um catálogo que especifique as metas e condições de entrega dos serviços.
Item avaliado	Q2201 - c) o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que não é possível constatar a acessibilidade de um catálogo de serviços, visto que tal instrumento não foi apresentado. A ausência de um catálogo de serviços estruturado inviabiliza a verificação da sua disponibilidade aos usuários. Inexiste evidência de portal, sistema ou documento de acesso amplo aos usuários e às equipes de suporte.
Item avaliado	Q2201 - e) a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que não há monitoramento contínuo de níveis de serviço (ANS) conforme exigido. As cláusulas do acordo referem-se ao acompanhamento administrativo



das ações da parceria, sem contemplar indicadores de desempenho ou metas de disponibilidade de serviços de TI. Falta a comprovação de monitoramento sistemático voltado aos serviços prestados aos usuários.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2204. A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2204 - A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada (Acordo de Cooperação Técnica nº 1/2024) não comprova a execução de processos de gestão de incidentes de TI ou de segurança da informação. O documento limita-se a estabelecer termos de cooperação mútua para suporte técnico, infraestrutura e capacitação, sem instituir normas, registros de chamados ou fluxos de trabalho específicos para a gestão de incidentes. A evidência é insuficiente por não conter os elementos operacionais exigidos para demonstrar a existência do processo. Falta a apresentação de documento normativo ou registros operacionais, como chamados ou relatórios de atendimento.
Item avaliado	Q2204 - a) a organização definiu regras para a priorização e o escalamento de incidentes
Resposta informada pelo auditado	Sim
Avaliação	Não há, no Acordo de Cooperação Técnica, regras ou critérios definidos para a priorização e escalamento de incidentes. O documento limita-se a estabelecer responsabilidades genéricas pela coordenação da parceria e suporte técnico. A evidência é insuficiente, pois faltam matrizes de impacto, severidade ou fluxos operacionais de escalonamento.
Item avaliado	Q2204 - b) a resolução de incidentes considera os níveis de serviços especificados em acordos com as áreas clientes
Resposta informada pelo auditado	Sim
Avaliação	O documento não estabelece níveis de serviço (SLAs) nem acordos com áreas clientes para a resolução de incidentes. O texto trata apenas de cooperação institucional e disponibilização de infraestrutura, sem vincular a resolução de demandas a tempos-alvo ou metas de disponibilidade. A evidência apresentada é insuficiente para comprovar a existência de tais acordos.
Item avaliado	Q2204 - d) o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
Resposta informada pelo auditado	Sim



Avaliação	O Acordo de Cooperação Técnica não constitui a formalização requerida para o processo de gestão de incidentes. Não foi apresentada norma interna, guia ou procedimento específico que defina etapas, papéis e responsabilidades para o tratamento de incidentes. A evidência é insuficiente por não apresentar o instrumento normativo do processo.
Item avaliado	Q2204 - e) a organização definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa
Resposta informada pelo auditado	Sim
Avaliação	O documento não define procedimentos ou responsabilidades quanto à notificação e tratamento de incidentes de segurança da informação. Embora existam cláusulas sobre sigilo e LGPD, não há diretrizes para ações emergenciais, escalamento ou comunicação específica para eventos de segurança. A evidência é insuficiente devido à ausência de fluxo ou norma de tratamento de incidentes de segurança.
Item avaliado	Q2204 - f) a organização definiu procedimentos e responsabilidades quanto à análise dos incidentes, identificação de causas raízes e planejamento e implementação de ações corretivas
Resposta informada pelo auditado	Sim
Avaliação	Não constam no Acordo de Cooperação Técnica procedimentos para análise de incidentes, identificação de causas raízes ou implementação de ações corretivas. O instrumento menciona apenas a "análise dos resultados" do acordo ao fim da vigência, sem relação com a gestão de incidentes de TI ou segurança. A evidência é insuficiente por ausência de metodologia ou registros de análise pós-incidente.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2501. A organização executa processo de gestão de ativos associados à informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2501 - A organização executa processo de gestão de ativos associados à informação.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A evidência apresentada (Decreto 48.209/2022) restringe-se à regulamentação do sistema SEI-RJ, não comprovando a execução de um processo de gestão de ativos associados à informação abrangente para toda a organização. O normativo estabelece regras operacionais, responsabilidades e controles limitados ao uso de sistema eletrônico específico. A ausência de inventário, análise de riscos e políticas de gestão aplicáveis à totalidade dos ativos de informação corporativos caracteriza a insuficiência da evidência.
Item avaliado	Q2501 - a) a organização mantém um inventário dos ativos associados à informação
Resposta informada pelo auditado	Sim
Avaliação	O Decreto 48.209/2022 não apresenta ou remete a um inventário de ativos associados à informação da organização. O normativo disciplina o funcionamento e os usuários do sistema SEI-RJ, mas não fornece listagem, catálogo ou relação de ativos de hardware, software, dados ou documentos. É necessária a apresentação de inventário formal que contemple os ativos de informação corporativos.
Item avaliado	Q2501 - b) a organização definiu responsabilidades pelos ativos associados à informação
Resposta informada pelo auditado	Sim
Avaliação	Embora o Decreto 48.209/2022 defina papéis e responsabilidades para o uso do sistema SEI-RJ, tais como usuários, pontos focais e administradores, não houve a definição formal de responsabilidades (propriedade) sobre a totalidade dos ativos de informação da organização. As atribuições elencadas limitam-se ao escopo operacional do sistema citado. Falta a comprovação de matriz de responsabilidade abrangente para os ativos de informação corporativos.
Item avaliado	Q2501 - d) o processo de gestão de ativos associados à informação subsidia a implantação de controles e ações com vistas a assegurar a adequada proteção dos ativos e das informações que armazenam, processam ou transmitem
Resposta informada pelo auditado	Sim
Avaliação	Os controles de proteção e segurança apresentados (acesso, assinatura eletrônica, auditoria de registros) são exclusivos do sistema SEI-RJ e não decorrem de um processo de gestão de ativos que garanta a proteção de todo o parque de ativos da organização. Não há demonstração de nexo causal entre o processo de gestão de ativos e os controles



mencionados. Ausente comprovação de controles aplicáveis aos ativos de informação para além do sistema citado.

Item avaliado	Q2501 - f) o processo de gestão de ativos associados à informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
Resposta informada pelo auditado	Sim
Avaliação	O Decreto 48.209/2022 constitui norma formal, porém disciplina apenas a operação do sistema SEI-RJ e não institui o processo de gestão de ativos associados à informação da organização. Não foi apresentada norma interna, guia ou instrumento similar que oriente a execução da gestão de ativos de forma transversal e institucional. É necessária a apresentação de normativo que contemple o processo de gestão de ativos de informação em âmbito corporativo.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2504. A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2504 - A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A organização não possui um Sistema de Gestão de Segurança da Informação (SGSI) formalmente definido e implementado. O relatório de conformidade (pág. 17) demonstra que a aderência total às práticas de segurança é limitada, com baixo índice de maturidade nos requisitos normativos. A ausência de um SGSI estruturado impede a correta gestão dos recursos de processamento da informação.
Item avaliado	Q2504 - c) a organização gerencia vulnerabilidades técnicas em seus ativos de software, de hardware e de rede críticos para o negócio
Resposta informada pelo auditado	Sim
Avaliação	Embora a organização realize a atualização automática de patches de segurança, não há um processo estruturado e contínuo para a gestão de vulnerabilidades. A ausência de uma metodologia formal de monitoramento e tratamento de vulnerabilidades limita a eficácia da proteção dos ativos.
Item avaliado	Q2504 - d) a organização implementa configurações seguras em seus ativos de software, de hardware e de rede críticos para o negócio
Resposta informada pelo auditado	Sim
Avaliação	Existe uma prática operacional de configuração segura, mas ela carece de documentação formal. A ausência de registros documentais impede a verificação da conformidade e a consistência das configurações aplicadas aos ativos críticos.
Item avaliado	Q2504 - e) a organização mantém, monitora e analisa logs de auditoria dos ativos de software, de hardware e de rede críticos para o negócio
Resposta informada pelo auditado	Sim
Avaliação	A organização reconhece a existência de um processo de gestão de logs, mas este não é centralizado nem documentado formalmente. A falta de centralização e registro formal prejudica a eficácia das análises de auditoria e resposta a incidentes.

Item avaliado	Q2504 - f) a organização aplica controles compensatórios para o uso de privilégios administrativos em seus ativos de software, de hardware e de rede críticos para o negócio
Resposta informada pelo auditado	Sim
Avaliação	Embora a gestão de acessos privilegiados ocorra de forma centralizada, o processo não está documentado e não apresenta evidências de revisão periódica. A falta de formalização compromete o controle sobre permissões administrativas elevadas.
Item avaliado	Q2504 - h) a organização limita e controla o uso de portas, protocolos e serviços de rede nas conexões de sua rede interna com a internet e outras redes externas
Resposta informada pelo auditado	Sim
Avaliação	O ambiente de rede é gerido integralmente pelo PRODERJ, conforme documentado no Acordo de Cooperação Técnica. A SETD não apresentou evidências de que exerce controle direto ou verificação sobre a gestão de portas, protocolos e serviços em sua rede.
Item avaliado	Q2504 - i) a organização implementa defesa de perímetro das conexões de sua rede interna com a internet e outras redes externas
Resposta informada pelo auditado	Sim
Avaliação	Similar ao controle de rede, a responsabilidade pela defesa de perímetro recai sobre o PRODERJ. Não foram apresentadas políticas próprias ou evidências de que a SETD gerencia ou supervisiona a defesa de perímetro de sua rede interna.
Item avaliado	Q2504 - j) a organização implementa cópias regulares de segurança (backup) das informações em meio digital, conforme as melhores práticas e as necessidades de negócio, incluindo a realização periódica de testes de recuperação das informações
Resposta informada pelo auditado	Sim
Avaliação	A organização depende da infraestrutura de backup do PRODERJ, contudo, não foram apresentadas evidências de que a SETD realiza testes periódicos de recuperação das informações, requisito essencial para assegurar a confiabilidade do backup.
Item avaliado	Q2504 - k) a organização executa regularmente testes de segurança em seu ambiente de TI (detecção de vulnerabilidades e testes de penetração)
Resposta informada pelo auditado	Sim
Avaliação	Não há um programa regular de testes de segurança ou testes de penetração (pentests). O documento apresentado é uma análise de lacunas (Gap Analysis), que constitui avaliação de conformidade, não possuindo a natureza de teste de segurança recorrente.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2701. Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de gestão de tecnologia da informação estão definidos e documentados.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2701 - Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de gestão de tecnologia da informação estão definidos e documentados.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A organização adotou parcialmente a medida, tendo formalizado a estrutura organizacional, competências das unidades e atribuições dos cargos no Regimento Interno aprovado pela Resolução SETD nº 98/2025. Contudo, não foram apresentadas evidências de perfis profissionais estruturados que incluam matrizes de competências, habilidades técnicas ou requisitos específicos além dos legais. A evidência é insuficiente por omitir a descrição detalhada do perfil requerido para o ocupante da função de gestão.
Item avaliado	Q2701 - c) relacionou-se, no perfil profissional, além de requerimentos de ordem legal, um conjunto de competências e habilidades que os ocupantes dos cargos de gestão devem possuir
Resposta informada pelo auditado	Sim
Avaliação	A documentação apresentada não contempla o conjunto de competências e habilidades esperadas para os ocupantes dos cargos de gestão além dos requisitos legais. O Regimento Interno limita-se a referências genéricas à formação e expertise, sem estabelecer uma matriz ou dicionário de competências técnicas e gerenciais. A evidência é insuficiente pela ausência de descrições de cargo que associem requisitos específicos à ocupação das funções.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2702. Os perfis profissionais desejados para cada ocupação ou grupo de colaboradores da área de gestão de tecnologia da informação estão definidos e documentados.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2702 - Os perfis profissionais desejados para cada ocupação ou grupo de colaboradores da área de gestão de tecnologia da informação estão definidos e documentados.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A avaliação da Equipe de Auditoria indica que o item não está plenamente atendido. Embora o PEDTIC (pp. 33-34) e o Decreto 49.580/2025 estabeleçam o quadro de pessoal e competências regimentais, não foram apresentados documentos que consolidem os perfis profissionais, contemplando responsabilidades, atribuições, competências e requisitos por ocupação. A evidência é insuficiente para a demonstração da definição desses perfis. Identifica-se a ausência de uma matriz de competências ou dicionário de cargos detalhado para a área de TI.
Item avaliado	Q2702 - d) a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que o item não está conforme. Embora a organização utilize mecanismos de transparência ativa, como o portal institucional e publicações no Diário Oficial, a evidência é insuficiente, visto que não existem perfis profissionais definidos e documentados a serem disponibilizados. A inexistência desses perfis inviabiliza a sua publicação. Não foram verificadas seções ou páginas específicas voltadas à transparência de perfis profissionais da área de TI.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2801. Os processos de trabalho relativos às contratações de tecnologia da informação estão definidos.

Itens avaliados como não conformes nesta questão:

Item avaliado Q2801 - a) o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa

Resposta informada pelo auditado Sim

Avaliação A avaliação realizada indica não conformidade, uma vez que a norma apresentada foca majoritariamente na fase de gestão contratual. O PEDTIC aborda o planejamento estratégico, mas não detalha as etapas, responsabilidades ou artefatos específicos do rito de planejamento de contratações de TI. A evidência é insuficiente para sustentar a afirmação. A lacuna relevante é a ausência de um fluxo de planejamento de contratação detalhado com papéis e entregáveis por etapa.

Item avaliado Q2801 - d) são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes

Resposta informada pelo auditado Sim

Avaliação A avaliação realizada indica não conformidade, dado que os documentos apresentados tratam exclusivamente da gestão e fiscalização de contratos, omitindo a fase de seleção de fornecedores. Não foram localizadas minutas de edital, checklists de seleção ou critérios de julgamento. A evidência é insuficiente. A lacuna relevante é a inexistência de artefatos padronizados para a fase de seleção.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2802. A organização executa processo de planejamento anual das contratações.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2802 - a) a alta administração (ou conselho ou colegiado superior) aprova formalmente o Plano de Contratações Anual (PCA)
Resposta informada pelo auditado	Sim
Avaliação	A evidência comprova a existência e publicação do PCA, contudo, não apresenta ato administrativo, ata ou resolução que demonstre a aprovação formal do Plano de Contratações Anual pela alta administração. Embora o PEDTIC mencione aprovação por comitê, trata-se de documento distinto do PCA. É necessário apresentar ato formal de aprovação específico para o PCA.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão Caso tenha assinalado que as contratações de soluções de TI são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI, forneça evidência de norma regulamentando esse processo e de um caso concreto.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2804 - a) as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que a evidência apresentada é insuficiente para atender ao requisito solicitado. O 'Acordo de Cooperação Técnica 1/2024' (páginas 1 a 10) formaliza uma parceria operacional entre a Secretaria de Estado de Transformação Digital e o Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro, não instituindo, contudo, norma ou regulamento que obrigue a análise prévia e a aprovação técnica da área de gestão de TI para todas as contratações de soluções de tecnologia. Constata-se a ausência de norma interna que estabeleça esse fluxo de governança, bem como a inexistência de caso concreto que demonstre a aplicação efetiva de tal controle.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP